

PHASE 3 — DoD VDP POLICY AUDIT REPORT

1. Safe Harbor Analysis (“Commitment” Section)

The DoD’s Safe Harbor language is designed to protect security researchers who follow the rules. In the policy, the DoD explicitly states that researchers will not face legal action if they operate within the authorized scope and follow the program guidelines. The policy states that the DoD “commits to not pursuing legal action for authorized testing activities” when researchers act in good faith.

What This Means in Practice

- Researchers are protected from **CFAA prosecution** as long as they follow the VDP rules.
- The DoD acknowledges that testing may cause **unintentional impact**, and it will not penalize researchers acting responsibly.
- The DoD commits to **coordinated communication**, reducing the risk of misunderstandings with law enforcement or internal security teams.

Connection to Your Instructor’s Feedback

Your instructor emphasized the importance of:

- **Immediate contact verification**
- **Clear reporting timelines**

The DoD VDP mirrors this: it provides direct communication channels and encourages prompt reporting of discovered vulnerabilities. This reinforces the idea that **good documentation and communication protect the tester**.

2. “Kill Switch” — Out-of-Scope Activities

The DoD VDP lists several categories that are strictly forbidden. The policy states that researchers must not test systems outside the authorized scope, including “any DoD information system not listed as in-scope.”

Three Explicit Out-of-Scope Areas

- **Any system not listed as in scope** — This includes classified networks, internal DoD systems, and any asset not explicitly authorized.
- **Social engineering attacks** — Phishing, vishing, impersonation, or attempting to trick DoD personnel is strictly prohibited.
- **Denial-of-Service (DoS/DDoS)** — Any action that degrades system performance or availability is forbidden.

Why This Matters

Your instructor's comment about **scope drift** is directly relevant here. The DoD VDP is extremely strict:

If it's not listed as in-scope, it is automatically out-of-scope.

This is the same principle you must apply in your Phase 2 RoE.

3. Verification Rules — Valid vs. Duplicate vs. Informational Findings

The DoD defines findings using three categories:

A. Valid Finding

A finding is considered **valid** when:

- It identifies a real security vulnerability
- It is reproducible
- It affects an in-scope asset
- It has not already been reported

The policy states that valid reports must include “clear steps to reproduce” and must demonstrate actual security impact.

B. Duplicate Finding

The finding is marked as a **duplicate** when:

- Another researcher has already reported the same issue
- The DoD has already acknowledged the vulnerability
- The issue is already being remediated

Duplicate findings are still appreciated but **not eligible for recognition**.

C. Informational Finding

A finding is **informational** when:

- It does not pose a security risk
- It is a configuration note, best practice suggestion, or low-impact observation
- It does not demonstrate exploitability

Informational findings help the DoD improve hygiene but are **not considered vulnerabilities**.